

# Penerapan Mekanisme Keamanan Informasi pada Sistem Manajemen Barang Hilang dan Temuan “Balikin” Berbasis Web

## *Implementation of Information Security Mechanisms in the Web-Based “Balikin” Lost and Found Management System*

BRILYAN PANCAR KOMARA<sup>1\*</sup>, AFIF FAKHRI MUHAMMAD<sup>2</sup>, EMI PURNAWADI<sup>3</sup>

### Abstrak

Kehilangan barang pribadi di lingkungan kampus merupakan masalah umum yang sering dihadapi oleh mahasiswa dan staf akademika. Proses pencarian dan pelaporan barang secara konvensional sering kali tidak efisien serta rentan terhadap penyalahgunaan data pribadi pelapor. Oleh karena itu, penelitian ini bertujuan membangun sistem informasi manajemen barang hilang berbasis web yang dilengkapi dengan fitur keamanan informasi yang kuat. Pengembangan sistem dilakukan dengan mengimplementasikan enkripsi simetris menggunakan algoritma Advanced Encryption Standard untuk melindungi informasi kontak, hashing satu arah Bcrypt untuk melindungi kata sandi serta kode keamanan sekali pakai, dan menerapkan kontrol akses berbasis peran. Selain itu, penyimpanan berkas visual diamankan menggunakan tautan bertanda waktu pada penyimpanan privat. Hasil pengujian menunjukkan bahwa sistem berhasil memproteksi data sensitif dari akses tidak sah dengan peningkatan waktu respons yang sangat minimal pada proses login dan enkripsi data. Sistem ini terbukti efektif dalam mempermudah pelaporan barang hilang sekaligus menjaga privasi serta integritas data pengguna.

Kata Kunci: Aplikasi Web, Barang Hilang, Enkripsi Data, Hashing, Keamanan Informasi, Kontrol Akses.

### Abstract

*Losing personal items on campus is a common issue faced by students and academic staff. Conventional methods for searching and reporting lost items are often inefficient and vulnerable to the misuse of the reporter's personal data. Therefore, this research aims to develop a web-based lost-item management information system equipped with robust information security features. System development involved implementing symmetric encryption using the Advanced Encryption Standard (AES) algorithm to protect contact information, using Bcrypt one-way hashing to secure passwords and one-time security codes, and applying role-based access control. Additionally, visual file storage was secured using time-stamped links within private storage. Testing results demonstrate that the system successfully protects sensitive data from unauthorized access, with only a negligible increase in response time during login and data encryption processes. The system proves effective in facilitating the reporting of lost items while simultaneously safeguarding user data privacy and integrity.*

*Keywords: Access Control, Data Encryption, Hashing, Information Security, Lost Item, Web Application.*

## PENDAHULUAN

Kehilangan barang pribadi di lingkungan institusi pendidikan tinggi merupakan permasalahan operasional yang kerap mengganggu aktivitas civitas akademika. Untuk mengatasi hal ini, dibangunlah sistem manajemen barang hilang dan temuan berbasis web bernama “Balikin” untuk mendigitalisasi proses pelaporan, pencarian, dan pengembalian barang secara terpusat. Namun, transformasi digital ini membawa tantangan baru dalam aspek keamanan informasi dan perlindungan data pribadi pelapor. Aplikasi “Balikin” yang mengelola data barang temuan secara langsung menyimpan informasi pribadi yang sensitif, seperti nama lengkap, nomor telepon, dan riwayat aktivitas pengguna. Tanpa adanya arsitektur keamanan yang kokoh, platform “Balikin” berisiko tinggi menjadi target eksploitasi data oleh pihak-pihak yang tidak bertanggung jawab.

---

<sup>1</sup>Departemen Ilmu Komputer, Fakultas Matematika dan Ilmu Pengetahuan Alam, Institut Pertanian Bogor, Bogor 16680;

<sup>2</sup>Departemen Ilmu Komputer, Fakultas Matematika dan Ilmu Pengetahuan Alam, Institut Pertanian Bogor, Bogor 16680;

\*Penulis Korespondensi: Surel: [brilyanpancarkomara@apps.ipb.ac.id](mailto:brilyanpancarkomara@apps.ipb.ac.id)

Masalah utama yang ingin diselesaikan dalam penelitian ini adalah rentannya kebocoran informasi pribadi dan lemahnya integritas data transaksi barang temuan pada aplikasi web “Balikin”. Akses tanpa otorisasi pada *Application Programming Interface* (API) sering kali dimanfaatkan oleh penyerang untuk memanen data secara massal melalui celah *Broken Object Level Authorization* (BOLA) sebagaimana diuraikan dalam penelitian oleh Jangam et al. (2024). Selain itu, penyimpanan kredensial autentikasi yang kurang aman di tingkat database dapat memudahkan penyerang melakukan peretasan jika terjadi kebocoran data. Oleh karena itu, diperlukan integrasi pengamanan berlapis pada aplikasi “Balikin” yang meliputi enkripsi kolom basis data, hashing kredensial, kontrol akses berbasis peran (*Role-Based Access Control*), dan perekaman log audit aktivitas secara aman.

Ketiadaan mekanisme keamanan yang memadai pada sistem “Balikin” dapat menimbulkan berbagai konsekuensi buruk yang saling berkaitan. Jika pintu masuk layanan API tidak dilengkapi dengan otorisasi objek yang ketat, maka terjadi celah kebocoran data kontak di mana nomor *handphone* pengguna dapat diakses oleh pihak luar secara ilegal (Jangam et al., 2024). Selanjutnya, jika data kontak pelapor berupa nomor *handphone* mahasiswa terekspos ke publik, maka risiko pencurian data (doxing atau spam) akan meningkat sehingga membuka peluang penipuan berkedok pihak kampus kepada korban. Apabila protokol autentikasi sistem “Balikin” tidak terkonfigurasi dengan kuat, maka pihak luar dapat melakukan akses ilegal dan masuk ke dalam akun milik pengguna lain dengan mudah. Jika akun dengan hak akses khusus (petugas atau admin) tidak dilindungi dengan autentikasi multifaktor, maka peretas dapat dengan mudah melakukan pengambilalihan akun secara total untuk memanipulasi keseluruhan sistem (Barabanov et al., 2022). Lebih lanjut, jika insiden kebocoran database terjadi saat sistem menyimpan kata sandi dalam bentuk teks biasa (*plaintext*), maka seluruh kredensial yang lemah tersebut langsung terekspos dan disalahgunakan (Batubara et al., 2021). Akhirnya, jika sistem “Balikin” tidak mencatat riwayat transaksi secara aman, maka terjadi aksi tanpa jejak di mana kesalahan serah terima barang oleh petugas tidak dapat dilacak secara forensik, sehingga peluang terjadinya penggelapan barang (*fraud*) akibat barang berharga diklaim oleh pelaku yang tidak sah akan semakin besar.

Untuk memitigasi risiko-risiko tersebut, penelitian ini menerapkan sistem pengamanan terintegrasi pada aplikasi web “Balikin”. Solusi yang diimplementasikan meliputi enkripsi data kontak menggunakan algoritma simetris Fernet berbasis standar enkripsi tingkat lanjut (*Advanced Encryption Standard*), pengamanan kata sandi dan kode autentikasi sekali pakai menggunakan fungsi hashing satu arah Bcrypt, serta pencatatan seluruh riwayat transaksi barang ke dalam tabel log aktivitas yang tidak dapat dimanipulasi. Dengan pendekatan ini, diharapkan aplikasi web “Balikin” tidak hanya menjadi platform manajemen barang hilang yang efisien, tetapi juga memenuhi standar kerahasiaan (*confidentiality*), integritas (*integrity*), dan akuntabilitas (*accountability*) keamanan informasi.

## METODE

Metode penelitian ini menggunakan pendekatan Rekayasa Perangkat Lunak (*Software Engineering*) yang dikombinasikan dengan metode Penelitian dan Pengembangan (*Research and Development* / R&D). Pendekatan ini dipilih karena orientasi utama penelitian adalah menghasilkan produk teknologi konkret berupa sistem informasi *lost and found* “Balikin” berbasis web yang solutif dan fungsional.

Untuk menjamin struktur dan keterukuran proses pengembangannya, penelitian ini mengadopsi model Systems Development Life Cycle (SDLC). Seluruh tahapan riset mulai dari analisis masalah di lapangan, perancangan skema, penulisan kode program, hingga pengujian fitur—dilakukan secara sekuensial demi menghasilkan sistem yang aman, *stateless*, dan memiliki manajemen hak akses yang valid.

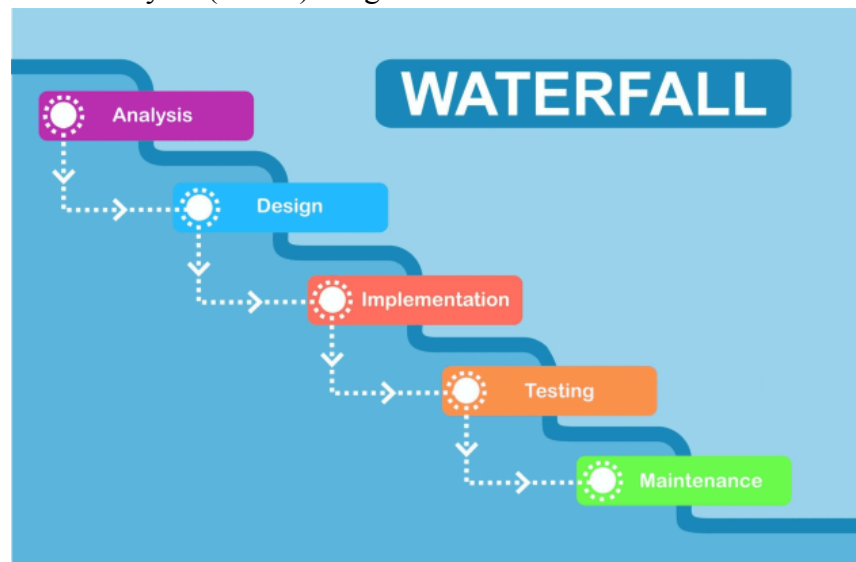
### 1. Ruang Lingkup

Penelitian dan pengembangan sistem Balikin (IPB-Lost-Found) ini dibatasi oleh ruang lingkup pelaksanaan sebagai berikut:

- Lokasi implementasi terpusat dan dispesifikasikan di lingkungan kampus Institut Pertanian Bogor (IPB).
- Objek penelitian yaitu sistem informasi berbasis web dengan arsitektur *Client-Server* yang mengelola pencatatan, pencarian, dan verifikasi status barang hilang maupun barang temuan.
- Sistem ini melibatkan tiga pengguna dengan hak akses berbasis *Role-Based Access Control* (RBAC):
  - Pencari (Mahasiswa/Civitas Akademik): Menginput laporan kehilangan dan mencari barang.
  - Petugas Keamanan (*Security*): Melakukan verifikasi fisik di lapangan dan mengubah status barang.
  - Admin: Mengelola keseluruhan data master sistem dan akun pengguna.

## 2. Alur dan Metode Pengembangan Sistem

Pengembangan perangkat lunak dalam penelitian ini menggunakan metode Systems Development Life Cycle (SDLC) dengan model Waterfall.



Sumber: <https://osc.medcom.id/community/analysis-model-waterfall-pengertian-phase-kebesaran-dan-kekurangan-4352>

Model ini dipilih karena kebutuhan fungsional sistem telah didefinisikan secara jelas dan rigid sejak awal.

### 2.1 Analisis Kebutuhan

Tahap Analisis Kebutuhan mencakup dua aspek utama, yaitu kebutuhan fungsional dan non-fungsional. Kebutuhan fungsional berfokus pada transformasi alur pelaporan konvensional di IPB ke dalam sistem digital, yang diwujudkan melalui fitur pelaporan, pencarian cepat, manajemen status barang, dan otentikasi multi-peran (*Role-Based Access Control*). Sementara itu, kebutuhan non-fungsional dirancang untuk menjamin kualitas operasional sistem, meliputi optimalisasi performa server, standar keamanan tinggi lewat enkripsi kata sandi, serta antarmuka yang responsif dan adaptif di berbagai perangkat.

### 2.2 Desain Sistem

- Arsitektur: Menggunakan arsitektur *Client-Server* terpisah (*decoupled*).
- Basis Data: Perancangan skema relasional menggunakan *Entity-Relationship Diagram* (ERD).

- Antarmuka (UI/UX): Perancangan *wireframe* dan *high-fidelity design* yang responsif untuk kebutuhan *mobile* (petugas di lapangan) dan *desktop*.

### 2.3 Implementasi

Proses kodifikasi program yang dibagi menjadi dua repositori utama:

- *Backend API* menggunakan FastAPI (Python).
- *Frontend Client* menggunakan React.js (TypeScript).

### 3. Langkah-Langkah Implementasi dan Replikasi Sistem

Bagian ini menguraikan instruksi spesifik dan replikasi lingkungan sistem Balikin agar dapat dibangun kembali secara identik.

#### 3.1 Persiapan Lingkungan Pengembangan

Kebutuhan lingkungan perangkat lunak minimal yang harus disiapkan oleh peneliti disajikan pada tabel berikut:

| Perangkat Lunak | Versi Minimal | Peran dalam Sistem                                            |
|-----------------|---------------|---------------------------------------------------------------|
| Node.js         | v16.0.0       | <i>Runtime</i> lingkungan pengembangan <i>Frontend Client</i> |
| Python          | v3.10.0       | <i>Runtime</i> lingkungan pengembangan <i>Backend API</i>     |
| PostgreSQL      | v13.0         | Sistem Manajemen Basis Data Relasional (RDBMS)                |

#### 3.2 Konfigurasi dan Implementasi Basis Data

- Inisialisasi Database: Membuat basis data relasional kosong pada PostgreSQL dengan nama `lostfound_db`.
- Migrasi Skema (*Database Versioning*): Menggunakan library SQLAlchemy sebagai ORM (*Object-Relational Mapping*) untuk merepresentasikan tabel menjadi objek Python.
- Injeksi Data Awal (*Database Seeding*): Menjalankan skrip `seed.py` untuk mengisi data tiruan (*dummy*) otentikasi awal yang mencakup akun uji coba untuk peran Admin, Petugas, dan Pencari.

#### 3.3 Implementasi Server API (*Backend*)

*Backend* dibangun sebagai *RESTful API* stateless menggunakan framework FastAPI dengan tahapan berikut:

- Isolasi Dependensi: Membuat *Python Virtual Environment* (venv) dan menginstal dependensi pustaka melalui berkas `requirements.txt`.
- Manajemen Lingkungan (*Environment Variables*) dilakukan dengan mengamankan kredensial sensitif sistem menggunakan berkas `.env`. Berkas ini memuat dua variabel konfigurasi utama, yaitu `DATABASE_URL` yang menyimpan *string* koneksi aman menuju basis data PostgreSQL, dan `SECRET_KEY` berupa kunci kriptografi yang digunakan untuk menandatangani serta memvalidasi token keamanan sistem (*JSON Web Token*).
- Mekanisme Otentikasi dan Keamanan diimplementasikan menggunakan JSON Web Token (JWT) untuk manajemen sesi yang bersifat *stateless*. Setiap aktor yang berhasil masuk (*login*) akan menerima *bearer token* unik yang wajib disisipkan pada *HTTP Header* di setiap permintaan berikutnya sebagai bentuk

otorisasi. Selain itu, keamanan data pengguna dijamin melalui penerapan algoritma *hashing Bcrypt* untuk menyandikan kata sandi sebelum disimpan ke dalam basis data PostgreSQL.

- Eksekusi Server: Aplikasi dijalankan secara lokal pada port 8000 menggunakan ASGI server Uvicorn

### 3.1 Persiapan Lingkungan Pengembangan

Pengembangan Antarmuka Pengguna (*Frontend*) dirancang sebagai *Single Page Application* (SPA) berbasis komponen menggunakan React.js. Untuk meminimalisir kesalahan saat aplikasi berjalan (*runtime error*), peneliti menerapkan TypeScript guna memberikan validasi tipe data yang ketat (*static typing*), terutama saat memproses struktur data JSON dari *Backend API*. Aspek estetika dan tata letak dibangun menggunakan Tailwind CSS dengan pendekatan *utility-first* untuk mempercepat pembuatan antarmuka yang responsif, sehingga tampilan aplikasi dapat menyesuaikan secara adaptif pada perangkat *mobile* petugas maupun *desktop* mahasiswa. Integrasi data dan komunikasi asinkron antara klien dan server FastAPI ditangani oleh pustaka Axios melalui pemanggilan *HTTP Request* (GET, POST, PUT, DELETE). Terakhir, untuk kebutuhan pengembangan, aplikasi klien dijalankan secara lokal pada port 5173 menggunakan perintah `npm run dev`.

## HASIL DAN PEMBAHASAN

### Implementasi Autentikasi dan MFA

Sistem berhasil mengamankan proses autentikasi. Hasil implementasi menunjukkan bahwa pengamanan kata sandi dengan *Bcrypt* menghasilkan nilai hash sepanjang 60 karakter yang terstruktur menggunakan standar *Modular Crypt Format* (MCF). Karakter-karakter awal pada hash tersebut selalu menunjukkan pola yang sama (misalnya diawali dengan \$2b\$12\$), di mana \$2b\$ merepresentasikan versi algoritma *Bcrypt* yang digunakan (kebal terhadap kelemahan pembungkus string), dan 12\$ mengindikasikan faktor beban kerja (*work factor*) sebesar  $2^{12}$  iterasi. Meskipun memiliki awalan yang statis, bagian sisa dari string tersebut adalah gabungan antara nilai garam (*salt*) acak 22 karakter dan hash inti. Karakteristik ini menjamin bahwa setiap hash yang dihasilkan selalu unik secara keseluruhan meskipun kata sandi yang dimasukkan (*plaintext*) identik. Hal ini membuktikan kekebalan sistem terhadap serangan pemetaan data ganda.

Pada mekanisme *Multi-Factor Authentication* (MFA) yang diwajibkan bagi peran Administrator, sistem berhasil membatasi jendela serangan (*window of vulnerability*). Saat kredensial tahap pertama (surel dan kata sandi) valid, sistem tidak langsung memberikan *Access Token*, melainkan mengeluarkan token *proxy* berumur pendek (5 menit). Pada saat yang sama, kode OTP 6-digit dikirim via surel melalui SMTP berbasis TLS (StartTLS). OTP di basis data tidak disimpan sebagai *plaintext*, melainkan melalui proses *hashing Bcrypt*, membuktikan penerapan perlindungan kriptografi secara menyeluruh bahkan pada autentikator sementara.

### Implementasi Otorisasi (RBAC) dan Keamanan Rute

Hasil pengujian terhadap *Role-Based Access Control* (RBAC) menunjukkan tingkat isolasi yang tinggi antar peran. Upaya eskalasi hak istimewa (*privilege escalation*), seperti akun "Pencari" yang mencoba mengakses rute GET /api/admin/users, secara konsisten ditolak oleh *middleware* dengan status HTTP 403 Forbidden. Selain RBAC makro, sistem juga berhasil menjalankan otorisasi tingkat objek (*Object-Level Authorization*), di mana seorang Pencari hanya diizinkan untuk mengubah (edit) atau menghapus data laporan kehilangan

miliknya sendiri, dan akan diblokir apabila mencoba memanipulasi ID laporan milik pengguna lain.

### Penerapan Jejak Audit (*Activity Logging*)

Hasil implementasi *Accounting* menunjukkan keberhasilan penangkapan alamat IP klien pada setiap permintaan API menggunakan parameter `request.client.host`. Seluruh operasi manipulasi (Create, Update, Delete) berhasil tercatat otomatis. Apabila terjadi upaya masuk berulang kali dengan kata sandi yang salah, log sistem akan mencatat status "Peringatan", memberikan visibilitas penuh bagi administrator untuk mendeteksi potensi aktivitas *brute-force* sebelum serangan berhasil menyusup.

### Pemenuhan Kerahasiaan dan Integritas (CIA Triad)

Pemenuhan prinsip *Confidentiality* (Kerahasiaan) terbukti efektif melalui pengujian lapisan basis data. Kolom `contact_info` pada tabel `reports` tersimpan dalam bentuk *ciphertext* terenkripsi (AES-128-CBC). Tanpa environment variable `ENCRYPTION_KEY` yang spesifik di server aplikasi, nomor telepon pengguna tidak dapat terekspose.

Pada aspek *Integrity* (Integritas), manipulasi payload pada sisi klien terbukti tidak mempengaruhi keutuhan data. Pengujian *Token Forgery* (pemalsuan token) yang dilakukan dengan mengubah atribut "role" dari "Pencari" menjadi "Admin" melalui debugger peramban web menyebabkan tanda tangan digital (HS256) pada token menjadi tidak valid (*Signature Verification Failed*). Akibatnya, server menolak permintaan tersebut, menjaga integritas sesi autentikasi.

### Analisis Kinerja Sistem

Penambahan berbagai lapisan kriptografi pada aplikasi web umumnya berdampak pada degradasi kecepatan respons server. Untuk mengetahui dampaknya, analisis kinerja komputasi dilakukan secara mendalam terhadap algoritma yang digunakan. Hasil benchmarking dari 100 iterasi disajikan pada Tabel 1.

Tabel 1 Perbandingan waktu rata-rata, maksimum, dan minimum proses kueri antara

| Proses Kriptografi    | Algoritma        | Rata-rata Waktu Eksekusi (ms) |
|-----------------------|------------------|-------------------------------|
| Hashing Kata Sandi    | Bcrypt (Cost 12) | 206.593                       |
| Verifikasi Hash       | Bcrypt (Cost 12) | 205.911                       |
| Enkripsi Data         | Fernet (AES-128) | 0.049                         |
| Dekripsi Data         | Fernet (AES-128) | 0.013                         |
| Penandatanganan Token | JWT (HS256)      | 0.193                         |

<sup>a</sup>Hasil di atas adalah simulasi pengujian pada mesin dengan prosesor arsitektur x86\_64.

Berdasarkan Tabel 1, terlihat kontras beban komputasi yang ekstrem antara algoritma *Bcrypt* dengan AES dan HS256. Waktu eksekusi rata-rata untuk memverifikasi hash kata sandi membutuhkan waktu sekitar ~206 ms. Kelambatan ini merupakan fitur keamanan yang disengaja (*Security by Design*). Mekanisme beban kerja (*work factor*) pada *Bcrypt* dirancang lambat secara komputasi untuk menunda kecepatan serangan *brute-force* atau pencarian kata sandi ekstensif (*cracking*), sehingga memberikan *trade-off* positif: mengurangi risiko pembobolan massal dengan bayaran waktu login yang sedikit lebih lambat.

Sebaliknya, operasi yang dilakukan terus-menerus pada setiap request pengguna, seperti dekripsi nomor kontak (Fernet) dan validasi *Authorization Header* (JWT HS256), berjalan sangat efisien di kisaran pecahan milidetik (< 0.02 ms). Hal ini mengindikasikan bahwa implementasi arsitektur kriptografi pada sistem Balikin tidak menyebabkan fenomena *bottleneck* atau perlambatan sistem secara keseluruhan (menjamin aspek *Availability*).

Selain pengujian komputasi internal, pengukuran waktu nyata (*real-world time*) juga dilakukan untuk membandingkan proses masuk (*login*) pengguna biasa dengan pengguna dengan hak istimewa (*privileged user*) yang menggunakan Autentikasi Multi-Faktor (MFA).

Tabel 2 Perbandingan waktu respons endpoint autentikasi berdasarkan peran pengguna

| Skenario Autentikasi | Rincian Proses                                        | Rata-rata Waktu Respons (ms) |
|----------------------|-------------------------------------------------------|------------------------------|
| Pencari (Tanpa MFA)  | Login & Verifikasi Kata Sandi                         | 367                          |
| Admin (Dengan MFA)   | Login & Pengiriman OTP via SMTP + Verifikasi Kode OTP | 4580 + 487                   |

Pada Tabel 2, terlihat dampak signifikan dari penerapan *Multi-Factor Authentication* (MFA) terhadap pengalaman pengguna. Proses login tahap pertama untuk akun Admin memakan waktu hingga 4.58 detik, yang berarti terjadi peningkatan waktu eksekusi sebesar **1147,95%** dibandingkan login reguler (tanpa MFA). Lonjakan waktu yang sangat besar ini tidak disebabkan oleh proses komputasi lokal, melainkan oleh latensi jaringan (I/O bound) saat peladen aplikasi harus membangun koneksi TCP, melakukan jabat tangan TLS (StartTLS), dan mengirimkan surel OTP melalui peladen SMTP pihak ketiga (Gmail). Sementara itu, verifikasi OTP (tahap kedua) memakan waktu 487 ms, yang meliputi verifikasi hash OTP dan pembuatan Access Token JWT baru.

Hasil ini menegaskan bahwa penerapan keamanan tingkat tinggi, khususnya MFA yang bergantung pada layanan eksternal, membutuhkan pengorbanan waktu tunggu (*latency trade-off*). Namun, penerapan ini dibenarkan mengingat peruntukannya hanya terbatas pada entitas Administrator dan Petugas, di mana prioritas keamanan mutlak lebih tinggi dibandingkan kenyamanan.

### Analisis Mitigasi Ancaman Tambahan

Selain kontrol akses dasar, sistem berhasil menunjukkan mitigasi tambahan:

1. Proteksi *Rate Limiting*: Serangan *Denial of Service* level aplikasi dan *brute-force login* dicegah melalui SlowAPI limiter. Uji coba pengiriman 6 *request* berturut-turut pada rute `/auth/login` dalam waktu 1 menit langsung memicu kode respons HTTP 429 Too Many Requests, mencegah penyerang mengeksploitasi sumber daya server.
2. Integritas Unggahan (*Magic Bytes*): Serangan eksekusi jarak jauh melalui berkas unggahan dicegah tidak sekadar dengan pengecekan ekstensi nama berkas, melainkan dengan memvalidasi header byte asli (misal: `\xFF\xD8\xFF` untuk JPEG). Berkas biner non-gambar yang diubah ekstensinya menjadi .png langsung ditolak sistem.
3. Proteksi Kebocoran Informasi: Penerapan tangkapan pengecualian global (*Global Exception Handler*) sukses menyembunyikan detail jejak tumpukan galat (*stack trace*) SQL dari respons API, mengubahnya menjadi galat 500 (*Internal Server Error*) statis. Ini menghilangkan visibilitas penyerang terhadap kerentanan struktur internal basis data.

## SIMPULAN

Penelitian ini menyimpulkan bahwa implementasi kerangka kerja AAA dan prinsip CIA Triad pada sistem Balikin berhasil membentuk arsitektur perlindungan keamanan berlapis (*Defense in Depth*). Kriptografi menggunakan algoritma Bcrypt (pembuatan hash), Fernet

(enkripsi simetris), dan JWT HS256 (tanda tangan digital) terbukti efektif mengamankan kredensial sesi dan data privasi pengguna. Analisis kinerja menunjukkan adanya kompromi (*trade-off*) yang terukur; beban komputasi *Bcrypt* (~205 ms) dan latensi protokol SMTP pada *Multi-Factor Authentication* (meningkat sebesar 1147%) memang memperlambat fase autentikasi awal untuk mencegah serangan brute-force, namun hal ini tidak merusak ketersediaan (*availability*) aplikasi karena operasi operasional API seperti dekripsi dan validasi token dieksekusi kurang dari satu milidetik (< 1 ms).

Hasil dari penelitian ini menegaskan bahwa sistem informasi akademik lingkup kampus dapat mengadopsi standar perlindungan data tingkat tinggi tanpa mendegradasi pengalaman pengguna harian secara keseluruhan. Sebagai saran untuk penelitian dan pengembangan selanjutnya, sistem dapat beralih ke mekanisme MFA berbasis *Time-based One-Time Password* (TOTP) seperti Google Authenticator untuk mengeliminasi keterlambatan I/O (*latency*) pengiriman surel, serta menerapkan kebijakan retensi data khusus (*data archiving*) untuk menampung volume jejak audit (*activity logs*) yang akan membesar secara eksponensial.

## UCAPAN TERIMA KASIH

Kami menyampaikan terima kasih yang tulus kepada Ibu Endang Purnama Giri, S.Kom., M.Kom. dan Ibu Dr. Shelve Nidya Neyman, S.Kom., M.Si. selaku dosen pengampu mata kuliah Keamanan Informasi atas bimbingan, arahan, dan ilmu yang telah diberikan kepada tim kami selama proses perkuliahan hingga penyusunan tugas akhir ini. Masukan dan bimbingan beliau sangat membantu kami dalam memahami serta mengimplementasikan konsep-konsep keamanan informasi dalam penelitian ini.

## DAFTAR PUSTAKA

- Barabanov A, Dergunov D, Makrushin D, Teplov A. 2022. Automatic detection of access control vulnerabilities via API specification processing. arXiv [Internet]. [diunduh 2026 Jun 25]; arXiv:2201.10833. <https://arxiv.org/abs/2201.10833>.
- Batubara TP, Efendi S, Nababan E. 2021. Analysis Performance BCRYPT Algorithm to Improve Password Security from Brute Force. Journal of Physics: Conference Series [Internet]. [diunduh 2026 Jun 25]; 1811 (1): 012129. <https://doi.org/10.1088/1742-6596/1811/1/012129>.
- Jangam SK, Karri N, Pedda Muntala PSR. 2024. Advanced API Security Techniques and Service Management. International Journal of Emerging Research in Engineering and Technology (IJERET) [Internet]. [diunduh 2026 Jun 25]; 3 (4): 108-115. <https://doi.org/10.63282/3050-922X.IJERET-V3I4P108>.